IS Audit Report of ABC Bank Data Center

2021



JULY 23

ABC Bank

Authored by: Rishab, Jyothi Parsad, Dwaraka Nath



PROJECT REPORT

TITLE: The IS AUDIT REPORT OF ABC BANK DATA Center

BACKGROUND:

Technology is critical in operating any modern-day organization, whether it is a private business or a government entity or any Bank. For large organizations like ABC Bank information technology (IT) equipment, hardware, and facilities are typically centralized in locations called "data centers." Due to the magnitude of the Bank's operations and its IT needs, the Bank's data centers, and varying skill sets required, the bank has outsourced the data center activities to XYZ Ltd, a public limited company with a long and creditable standing. These facilities support the technology used by ABC Bank which, in turn, helps the Bank to provide critical services to its clients. The data center of the ABC Bank centralizes and shares IT operations and equipment for the purposes of storing, processing, and disseminating data and applications. Data Center of the bank house most critical and proprietary assets that are vital to the continuity of daily operations. The security and reliability of data center and their information are among Banks' top priorities. The Bank authorities want to assess the readiness of their operations for compliance with IT regulatory requirements for the efficacy of the bank's Digital Assets, IT planning and implementation. Bank wants to check the Internal controls procedures of the information system in obtaining reliable and accurate information from the IT system for ensuring the confidentiality, integrity and continued availability of IT assets.

PURPOSE - AUDIT OBJECTIVES

The objective of the exercise is to evaluate the adequacy, effectiveness, and efficiency of controls in place to minimize the risk of unauthorized access to the data center, business disruptions, Proper storage and prevention of theft of information assets, safety, emergency and environmental hazards, Document Management, Review of SLA.

EXECUTIVE SUMMARY OF CLIENT AND ASSIGNMENT OBJECTIVES

A data center of the ABC Bank Ltd. centralizes and shares IT operations and equipment for the purposes of storing, processing, and disseminating data and applications. Data Center of the bank has the most critical and proprietary assets that are vital to the continuity of daily operations. This makes the security and reliability of data center and its information ABC Banks' top priorities.

The IS audit intends to determine whether ABC Bank Data Center has identified:

1. Logical, physical, and environmental threats.

2. Assessed the risk or impact presented by the threats.

3. Determined the feasibility of implementing controls to address the risks

4. Implemented appropriate controls and re-assess risks periodically.

The Audit objective was to substantiate the internal controls of the data center to mitigate risks. The audit objectives include assuring compliance with legal and regulatory requirements as well as the confidentiality, integrity, reliability and availability of information and IT Resources.

The purpose of Infrastructure IS audit was to identify control objectives and the related controls so as to express an opinion on whether the internal control system set up and operated by the data center censor the purpose of managing risks to the achievement of the objectives are suitably designed and operated effectively.

The Audit work includes interviews with data center authorities & personnel, walkthroughs and inspections of the facilities, observations, and review of documentation and equipment configurations. We have reviewed safeguards to prevent unauthorized access to server operating systems and reviewed procedures to update and patch server operating systems. We reviewed physical controls, doorways, and access systems, monitoring functions, and the physical layout of the data center. Our Audit work included reviewing controls over environmental threats and man-made threats.

Overall, there is not a process in place to ensure the continuity of data center operations or for management to make an informed decision about the appropriateness, cost effectiveness, and necessity of implementing data center controls. Data Center has taken a minimal approach to securing the existing data center. Data Center performs damage control and remediation as problems arise, but does not eliminate or reduce all known threats proactively

Our Audit report contains recommendations for the followings:

1. Implementing an overall process to ensure threats to the data center are addressed.

2. Implementing safeguards over physical security to prevent unauthorized access.

3. Strengthening safeguards to mitigate threats.

4. Coordinating disaster recovery efforts and

5. Defining responsibilities for data center security and coordination.

Term of Assignment

The management of ABC Bank has approached us to perform an independent IS Infrastructure Audit of the bank's data center for appraising the security and control practices to provide assurance to the management and regulators towards the readiness of the operations for compliance with IT regulatory

requirements for the efficacy of the Bank's Digital Assets, IT planning and implementation.

SCOPE OF ASSIGNMENT

The IS Audit assignment involves benchmarking of Data Center operations with global best practices of security and controls, review compliance with banking rules as per regulations and review Process rules as applicable to Bank.

IS audit is expected to provide reasonable assurance to bank management by reviewing the availability, adequacy, and appropriateness of controls to provide for a safe and secure computing environment for the bank and its customers.

The key objectives of IS Audit is to enhance the security of banking data center operations and provide assurance to management and regulators on availability of security and controls as per international best practices as applicable to banking.

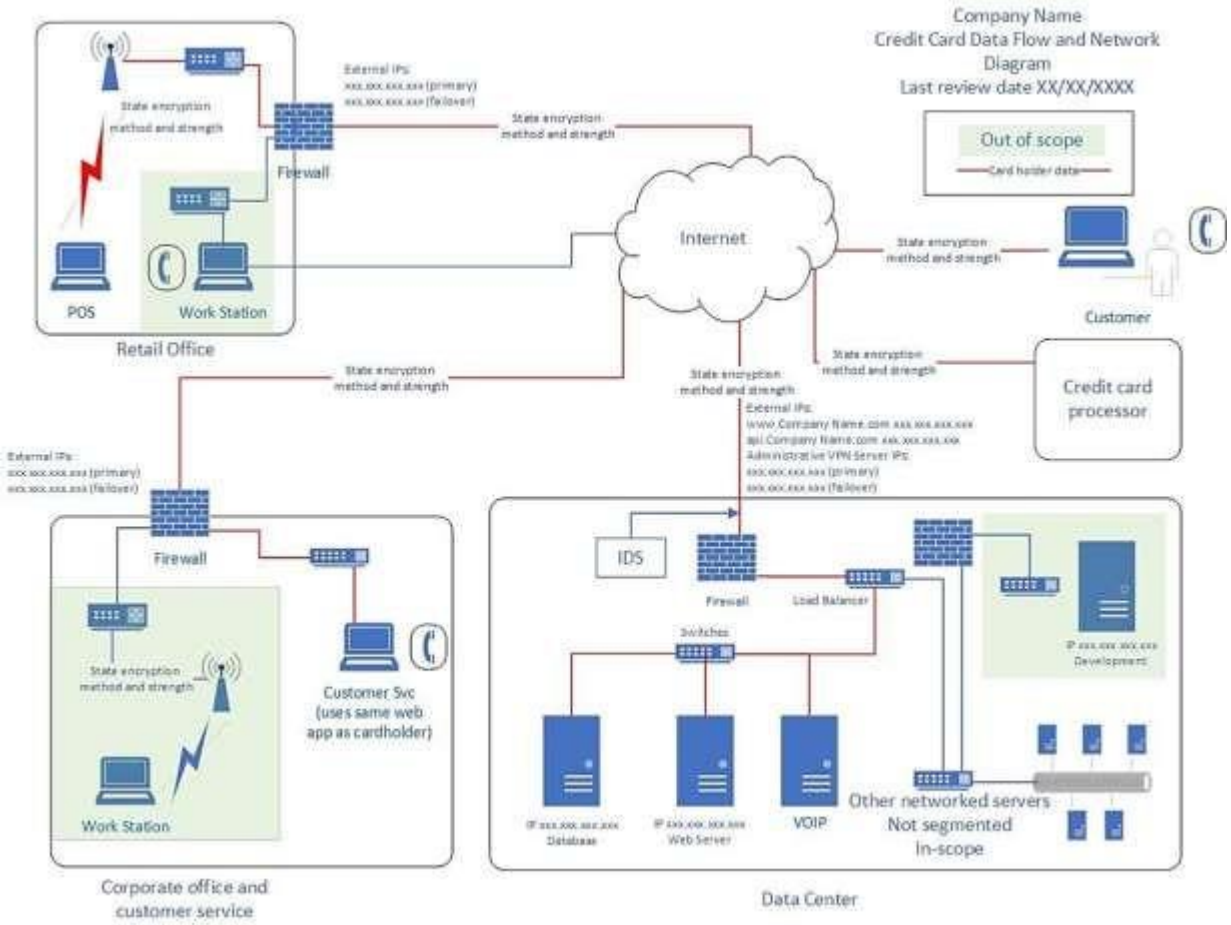
The specific area of audit includes the following:

1. Review of security and controls at each layer of system, network, and database.
2. Review of all the key functionalities and related Security and Access Controls as designed at the parameter level.
3. Review how the banking process business rules and regulatory requirements have been designed and built in the package.
4. Review Applications covering functionalities and how these facilitate performance of process controls as per bank policy and regulation.
5. Mapping of best practices of security and controls to evaluate the design of security and control.

The overall objective of the IS audit of bank data center is to ensure that the following seven attributes of data or information are maintained:

1. **Effectiveness** in dealing with information being relevant and pertinent to the business processes as well as being delivered in a timely, correct, consistent and usable manner.
2. **Efficiency** concerning the provision of information through the optimal (most productive and economical) usage of resources.
3. **Confidentiality** concerning the protection of sensitive information from unauthorized disclosure.
4. **Integrity** related to the accuracy and completeness of information and its validity in accordance with the business' set of values and expectations.

5. **Availability** related to information being available when required by the business process, and also concerned with the safeguarding of resources.
6. **Compliance** with laws, regulations and arrangements essentially meaning that systems need to operate within the ambit of rules, regulations and/or conditions of the organization.
7. **Reliability** of information.


Company Name
Credit Card Data Flow and Network Diagram
Last review date XX/XX/XXXX
Out of scope
Card holder data
Internet
Firewall
POS
Work Station
Retail Office
Customer
Credit card processor
IDS
Firewall
Load Balancer
Switches
Customer Svc (uses same web app as cardholder)
Work Station
Corporate office and customer service
VOIP
Other networked servers Not segmented In-scope
Web Server
Database
Development
Data Center

ABC BANK LTD.

The ABC Bank Ltd. Is regulated under the Banking Regulation Act, 1949 and the Reserve Bank of India Act, 1934. The main objectives of the Bank are:

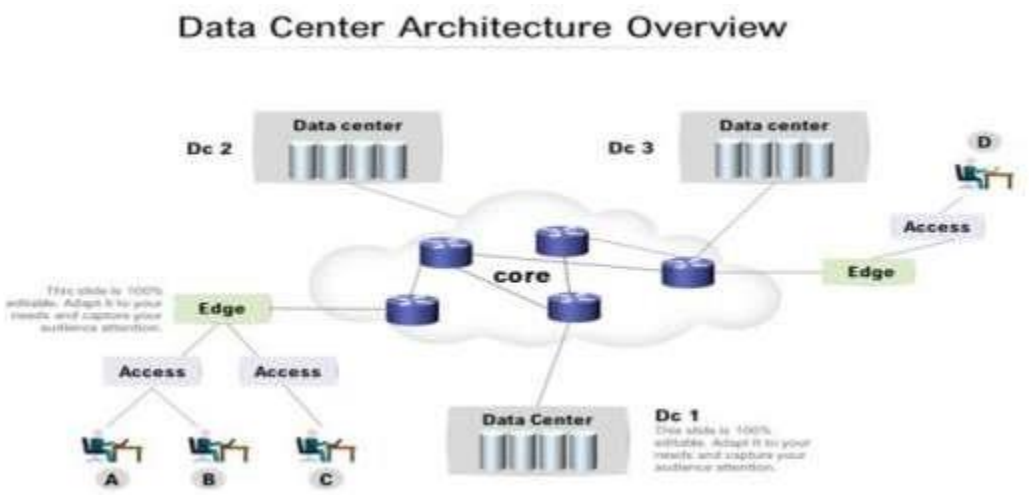
1. To establish and carry on the business of a Banking Company
2. Lending/advancing money
3. Deal in securities both of its own and on behalf of the customers
4. Carry on and transact guarantee and indemnity business etc.

The data center of the ABC Bank centralizes and shares IT operations and equipment for the purposes of storing, processing, and disseminating data and applications. Data Center of the bank house most critical and proprietary assets that are vital to the continuity of daily operations. The security and reliability of data centers and their information are among Banks' top priorities.

ABC Bank data center is operated by 300 people out of whom 250 are from an outsourced company. There are 50 applications running including their core banking solution. Around 100 plus network devices like firewall, IDS, IPS, Router, Switches, Gateways etc. are there along with 500 plus high-end servers. The asset register maintained by the bank is not updated and not reviewed for the last two years. It is difficult to get the idea of location and ownership of the asset. There is a Network operation center (NOC), a building management system (BMS) and a security operation center (SOC) separately placed along the data center. All the infrastructures are managed by the outsourcing agency.

ABC Bank was having issues with access control mechanism. The menu access was not controlled by any authorization matrices. Anybody can access any menu in the core banking systems.

There were cases of violation of logical access control recorded in incident register, but no follow-up action was made. In the data center, the testing team and development team share the same server and at times with the permission of the system administrator they access the production system and implement the program. There is no librarian to maintain version control. Change management system is also not application driven and done manually. User access review being done once in a year. DBA team controls the patch management system, and the network management team takes care of anti- malware system. There are also issues with the management of backup tapes and blank tapes.
ABC Bank's data center needs a biometric access system, but the management feels that implementing biometric control to regulate entry of people in the data center will be too costly and complex for them. They plan to appoint extra security guard as a compensatory control who is instructed to allow only those people into Data Center who is having appropriate access card and maintaining a register for entering access details which is supervised by the security officer



THE ENVIRONMENT:

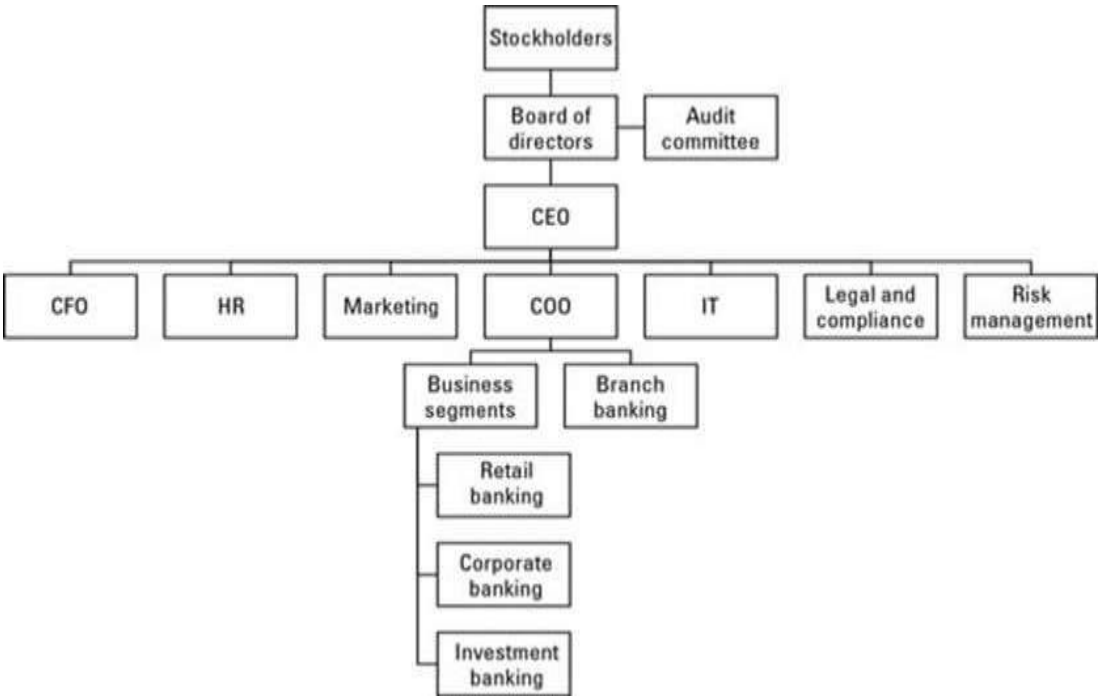
A data center of ABC Bank centralizes shared IT operations and equipment for the purposes of storing, processing, and disseminating data and applications. Most critical and proprietary assets of the Bank are maintained at the data centers that are vital to the continuity of daily operations. The security and reliability of data centers and their information are among bank's top priorities.

The ABC Bank authorities want to assess the readiness of their operations for compliance with IT regulatory requirements for the efficacy of the bank's Digital Assets, IT planning and implementation mainly for the following reasons

2. To check the Internal controls procedures of the information system in obtaining reliable and accurate information from the IT system for ensuring the confidentiality, integrity and continued availability of IT assets as the asset register is not maintained and updated by the bank regularly which makes difficult to get the idea of location and ownership of the asset.

3. The Network operation center (NOC), a building management system (BMS) and a security operation center (SOC) separately placed along the data center. All the infrastructures are managed by the outsourcing agency.

ORGANIZATION STRUCTURE:



CONTROL OBJECTIVES:
(AREAS OF CONCERN) INFORMATION SECURITY CONTROLS

INADEQUATE IS SECURITY POLICY IMPLEMENTATION:

The Bank Security Policy appears to be a restricted to System Administrators only and no other means of its dissemination to the operational staff.

INADEQUATE SECURITY AT DATA CENTER:

There were no Physical Access Controls for safeguarding critical areas like Server room, Communication room, UPS room. The access control system installed was not functioning and no alternate arrangements had been made. Even though the Bank had a Security Policy, the doors did not have mechanical bolts/locks. Proper locking system at the main entry door (glass) was neither provided nor a Physical Security Officer appointed. The Head of Data Center stated that the problems concerning improvement in infrastructure / security at Data Center.

INADEQUATE NETWORK SECURITY:

Use of Internet in the Bank has exposed its Local Area Network (LAN) to outsiders, making it imperative to secure the network against unauthorized intrusion to protect information assets critical to the smooth operation and the competitive wellbeing of the Bank. The Bank had so far not put any Intrusion Prevention System (IPS) or Enterprise Security Solutions in place while opening new services like e-Banking etc. to its customers.

LOGICAL ACCESS CONTROLS:

The lack of security renders the system vulnerable to unauthorized access. There are issues with access control mechanism. The menu access is not controlled by any authorization matrices. Anybody can access any menu in the core banking systems. This has a catastrophic vulnerable risk to the Bank and its assets .

The violation of logical access control is inevitable. The testing team and development team share the same server and at times with the permission of the system administrator they access the production system and implement the program. In the Data Center there is no librarian to maintain version control.

INADEQUATE DOCUMENTATION AND CHANGE MANAGEMENT CONTROL:

The bank is not maintaining proper documentation of activities such as backups, password changing (activation and deactivation), declaration from staff regarding maintaining secrecy of passwords, software problem register, AMC register, IT assets inventory register etc.

All system changes, whenever made, are not authorized at appropriate levels, documented, thoroughly tested, and approved. No records were maintained for the changes made in the System or Application Software or the master data, from time to time especially the changes made in rate of interest on various schemes at the branch level.

The readability of the critical backup media is also not tested periodically for restorability. Lack of systematic procedure for regular backup and not regularly checking the usability of the backup has the risk of disruption in operations when the backup data are use.

Change management system is also not application driven and done manually. User access review being done once in a year. DBA team controls the patch management system, and the network management team takes care of anti-malware system. There are also issues with the management of backup tapes and blank tapes

INADEQUATE IT ASSETS INVENTORY MANAGEMENT

The banks' asset register is not maintained and updated by the bank regularly making it is difficult to get the idea of location and ownership of the asset.

TERMS AND SCOPE OF ASSIGNMENT:

Term of Assignment

The management of ABC Bank has approached us to perform an independent IS Infrastructure Audit of the bank's data center for appraising the security and control practices to provide assurance to the management and regulators towards the readiness of the operations for compliance with IT regulatory requirements for the efficacy of the Bank's Digital Assets, IT planning and implementation.

SCOPE OF ASSIGNMENT

The IS Audit assignment involves benchmarking of Data Center operations with global best practices of security and controls, review compliance with banking rules as per regulations and review Process rules as applicable to Bank.

IS audit is expected to provide reasonable assurance to bank management by reviewing the availability, adequacy, and appropriateness of controls to provide for a safe and secure computing environment for the bank and its customers.

The key objectives of IS Audit is to enhance the security of banking data center operations and provide assurance to management and regulators on availability of security and controls as per international best practices as applicable to banking.

The specific area of audit includes the following:

1. Review of security and controls at each layer of system, network, and database.
2. Review of all the key functionalities and related Security and Access Controls as designed at the parameter level.
3. Review how the banking process business rules and regulatory requirements have been designed and built in the package.
4. Review Applications covering functionalities and how these facilitate performance of process controls as per bank policy and regulation.
5. Mapping of best practices of security and controls to evaluate the design of security and control.

The overall objective of the IS audit of bank data center is to ensure that the following seven attributes of data or information are maintained:

8. **Effectiveness** in dealing with information being relevant and pertinent to the business processes as well as being delivered in a timely, correct, consistent and usable manner.

9. **Efficiency** concerning the provision of information through the optimal (most productive and economical) usage of resources.
10. **Confidentiality** concerning the protection of sensitive information from unauthorized disclosure.
11. **Integrity** related to the accuracy and completeness of information and its validity in accordance with the business' set of values and expectations.
12. **Availability** related to information being available when required by the business process, and also concerned with the safeguarding of resources.
13. **Compliance** with laws, regulations and arrangements essentially meaning that systems need to operate within the ambit of rules, regulations and/or conditions of the organization.
14. **Reliability** of information.

LOGISTIC ARRANGEMENTS REQUIRED:

The logistics required for performance and discharge of our audit obligations are as follows:

1. Standard Operating Manual in use, Procedure, Duty Delegation and Organization Chart as well as the reporting mechanism.
2. Operating documentation and records such as prior audit reports and corrective action taken report.
3. Security Policy
4. Vulnerability assessment of Infrastructure relating to CBS Network, Data Center
5. Assets Register - Scrutiny of documents relating to development, implementation, procurement of hardware and software.
6. Access to information servers, Log reports.
7. Minutes of the Steering Committee.
8. Various Frameworks, Laws, Regulations as implanted at the bank and the data center
9. Service Level agreements with the outsourcing agencies/service providers etc.

10. Risk Register.

11. Interaction and interview of Human resources at key position at the data center.

12. Physical Infra Structure of the Data Center.

13. Travel & living arrangements (Audit team members).

14. Audit plan pre-approval.

15. Audit authorization: memo, letter, schedule.

Audit Team Dwaraka Nath , DISA, Lead IT Auditor
Rishab Kansal , DISA, Lead IT Auditor
Jyothi Parsad, DISA, Senior IT Auditor

AUDIT DETAILS (TIMELINE)

Receiving of Appointment /Engagement Letter	1st week of July ,2021
Sharing of Audit plan:	2nd week of July 2021
Audit Start Date:	15th July 2021
Audit Ending Date:	22nd July 2021
Submission of Report (Draft):	23rd July 2021
Submission of Report (Final):	25th July 2021

METHODOLOGY AND STRATEGY ADAPTED FOR EXECUTION OF INFRA STRUCTURE AUDIT ASSIGNMENT OF DATA CENTER:

We have been provided list of key security and control practices and are required to review the adequacy of these control practices and provide additional detailed procedures as relevant to Indian regulations considering Information Technology Act and other compliances applicable for Indian banking companies. We have conducted and reviewed the following documents and procedures for the purpose of our audit and framing our report.

1. Vulnerability assessment of Infrastructure relating to CBS Network, Data Center.

2. Functional audit for reviewing the maintenance of a well-controlled (Physical & Logical) environment, and Data Center covering Parameter / Access / Back-end corrections /Change Management.

3. Testing of the general IT controls

4. Testing of application controls in IT applications running in the Bank's Data Center

5. Risk Identification and Management (Threats & Vulnerabilities)

6. IT Governance (Management participation)
7. Scrutiny of documents relating to development, implementation, procurement of hardware and software.
8. Disaster Recovery Plan and Procedure
9. Backup Policy
10. Compliance Testing: Scrutiny of IT security policy adopted and implemented by the Bank.
11. Substantive Testing: Analyzing and checking the bank database for assessing completeness, correctness, and reliability of data.
12. Testing of application controls in IT security system.
13. Interaction with the Management.
14. IT Control Audit: General and Application Controls
15. Understanding of IT Resources deployment
16. Understanding of the IT Strategy and internal control system
17. Review of IT Outsourcing Policy
18. Identification and documentation of IT related Circulars
19. Identification and documentation of Organization Structure and Information Architecture
20. Assessing the performance of the bank data center against:
    a. **COBIT-19 Framework** about acquisition and maintenance of Assets and implementation of IT.
    b. Circulars/Instructions /Policy regarding Banking Operations and IT policy
    c. Security policy of the Bank and
    d. **RBI guidelines** on various issues like in-operative accounts, Anti money laundering policy etc.

AUDIT PROCEDURE:

Audit of IT Controls at the Data Center:

IT controls can be classified as:

1. General Controls
2. Application Controls.

General IT controls are concerned with the organization's IT infrastructure, including any IT related policies, procedures and working practices.
General controls include controls related to

1. Data center operations,
2. System software acquisition and maintenance,
3. Access security, and
4. Application system development and maintenance.
5. Organization and management controls (IT policies and standards).
6. IT operational controls.
7. Physical controls (access and environment).
8. Logical access controls.
9. Acquisition and program change controls.
10. Business continuity and disaster recovery controls.

For accessing the General Controls, we have reviewed the followings:

1. IT policies, standards, and guidelines pertaining to IT security and information protection.
2. Application software development and change controls,
3. Segregation of duties,
4. Business continuity planning policy,
5. IT project management

Application IT controls are specific computer application controls. They include controls that help to ensure the proper authorization, completeness, accuracy, and validity of transactions, maintenance,

and other types of data input.

Application controls include controls related to:

1. Controls over the input of transactions.

System ed it checks of the format of entered data to help prevent possible invalid inputs.

2. Controls over processing.

System enforced transaction controls preventing users from performing transactions that are not part of their normal duties.

3. Controls over output.

Creation of detailed reports to ensure all transactions have been posted completely and accurate. Controls over standing data and master files.

PROCEDURE ADOPTED FOR AUDITING OF GENERAL AND APPLICATION IT CONTROLS AT THE DATA CENTER

Our audit team have personally monitored the day-to-day performance of the system at the data center in terms of measuring the

1. Response time.
2. Initial Program loading for booting up the systems.
3. Media Management for control of devices
4. Job Scheduling and processing
5. Back-ups of data and software.
6. Maintenance of both hardware and software.
7. Network Monitoring and Administration.

Our audit team has reviewed and discussed Service Level Agreement with the other departments of the bank and the data center operations for specifically understanding and agreement of levels of service, in terms of quantity and quality.

We have considered following point while reviewing the SLA.

1. General provisions including the scope of the agreement, its signatories, date of next review.
2. Brief description of services.
3. Service hours.
4. Service availability (percentage availability, maximum number of service failures and the maximum downtime per failure);

5. Performance (response times, turnaround times);

6. Security and Restrictions

AUDIT OF PHYSICAL CONTROL (ACCESS AND ENVIRONMENT) OF THE DATA CENTER:

The objective of physical and environmental controls is to prevent unauthorized access and interference to IT services. In meeting the objective computer equipment and the information they contain, and control should be protected from unauthorized users. They should also be protected from environmental damage.

CONTROL OBJECTIVES & PROCEDURE ADOPTED FOR AUDITING OF PHYSICAL ACCESS CONTROLS AT THE DATA CENTER:

Checklist for verifying the Physical Access Controls

S. No	Audit Procedures	Yes/No
1	Is there a policy regarding physical access control?	Yes
2	Is physical access control policy part of the security policy	Yes
3	Is there a mechanism for reviewing the policy regularly?	Yes
4	Is there a policy for the following? Are they appropriate? 1.Lay out of facilities 2.Physical and Logical Security 3. Safety 4.Access 4. Entrance and exit procedures 6. Regulatory requirements	No
5	Is the Data Center and Information Systems facility being? located in a place which is not obvious externally?	Yes
6	Is the access facility at the data center limited to approve? personnel only?	No
7	Are the physical access control procedures being adequate for employees, vendors' equipment, and facility maintenance? staff?	No
8	Are the 'Key' management procedures and practices being adequate? Whether review and updates are carried out on a least access needed basis?	No
9	Is the access and authorization policies adequate?	No
10	Are the policies laid down implemented?	No
11	Whether periodic review of access profiles is carried out?	Yes
12	Whether revocation, response, and escalation process in the	

	event of security breach appropriate?	Yes
13	Whether air-conditioning, ventilation, and humidity control procedures in place, tested periodically and given adequate attention? Environment in the Data center is controlled by having adequate cooling systems.	Yes
14	Whether security awareness is created not only in IS function but also, across the organization?	No

15	Is the physical security continually addressed at the data center where bank assets either physical or data are? processed?	Yes
16	Is there security check in place, so that Photography of the Data Center facilities is prohibited by the Employees and Outsiders? Are the Information boards clearly placed at difference points saying Photography is prohibited?	Yes
17	Whether UPS is available? If so, is it covered under maintenance?	Yes
18	Whether alternate or re-routing telecommunication lines are available?	Yes
19	Whether alternative water, gas, air-conditioning and humidity resources are available?	Yes
20	Are All un-used power sockets, telephone points closed?	Yes
21	Whether all access routes are Identified and controls are in place?	Yes
22	Whether appropriate access controls like password, swipe card, bio-metric devices etc. are in place and adequate controls exist for storing the data / information on them?	No
23	Whether access to the IS facility & Data center is enabled only through ID cards / badges, etc., are there controls to ensure that the issue and re-collection of such access devices are authorized and recorded. Such unissued ID Card/badges should be stored in safe vaults.	Yes
24	Whether access to Data Center is given to Employees on need basis only based on the job-profile?	Yes
25	In case of outsourced software, whether all maintenance work is carried out only in the presence of / with the knowledge of appropriate Maintenance Department or Security Staff?	Yes

AUDIT OF LOGICAL ACCESS CONTROL OF THE DATA CENTER

The Logical access controls are for protecting the applications and underlying data files from unauthorized access, amendment, or deletion by limiting access and ensuring:

1. Users have only the access needed to perform their duties.

2. Limited access to sensitive resources such as security software program.

Logical access controls depend on the in-built security facilities available under the operating system or hardware in use.
Our audit Team has reviewed the most common form of logical access control that is the login identifiers (ids) followed by password authentication. For passwords to be effective there must be appropriate password policies and procedures, which are known to all staff and adhered to.

CONTROL OBJECTIVES & PROCEDURE ADOPTED FOR AUDITING OF LOGICAL ACCESS CONTROLS AT THE DATA CENTER

S. No	Audit Procedures	Yes/No
1	Whether the user access management policy and procedure are documented? Whether the user access management policy and procedure are approved by the management?	Yes
2	Whether the user access management policy and procedure document include Scope and objective, Procedure for user ID creation, approval, review, suspension, and deletion, Granting access to third parties, Password management, User access rights assignment & modifications, Emergency access Granting, Monitoring access violations, Review, and update of document.	Yes
3	Whether User ID & access rights are granted with an approval from appropriate level of IS and functional head? Is such request for creation of User ID clearly documents and they? based on the job profile of the employee?	Yes
4	Whether the organization follows the principle of segregation of duties adequately in granting access rights? (Verify Access rights should be given on need to know and need to do basis – without unchecked concentration of power.)	Yes
5	Whether USER IDs are in unique format?	Yes
6	Whether invalid log in attempts are monitored and User IDs are suspended on specific attempt?	Yes
7	Whether the organization follows complex composition for password parameters? Minimum length for password should	Yes

	be 8 letter and should contain a combination of Upper and lower alphabets and special characters?	
8	Whether users are forced to change password on first logon and at periodic intervals? IS the Periodic Interval set for change is as per sensitivity of the Role?	Yes
9	Whether the organization restricted concurrent log-on? Verify whether that the User ID access is restricted to one Terminal only? Whether users' IDs are shared?	Yes
10	Whether User IDs and Password are communicated to the user in a secured manner initially or at the time of resetting?	Yes
11	Whether the organization reviews user IDs and access rights at periodic intervals?	Yes
12	Whether the organization monitors logs for the user access?	Yes
13	Whether policy and procedure documents reviewed and updated at regular intervals?	Yes
14	Whether the access to scheduled job is restricted to the authorized?	Yes
15	Whether passwords are shadowed and use strong hash functions?	Yes

AUDIT OF NETWORK CONTROL OF THE DATA CENTER

The Network Controls are for controlling the access the network resources only to authorized users. Control of networks is not just about logical access security.

Networks are primarily used to transmit data. When data is transmitted, it may be lost, corrupted or intercepted. Our audit Team has reviewed the Network access controls to reduce all these risks. We have reviewed the followings for the above purpose:

1. Network security policy. It was part of the overall IT security policy

2. Network documentation describing the logical and physical layout of the network

3. Logical access controls.

CONTROL OBJECTIVES & PROCEDURE ADOPTED FOR AUDITING OF NETWORK CONTROLS AT THE DATA CENTER

S. No	Audit Procedures	Yes/No
1	Whether there is an Acceptable usage Policy, Internet Access Policy, Email and Communication Policy, Network Security Policy, remote Access Policy, Encryption Policy, Privacy Policy? Are the policies clearly defined and communicated to the various stakeholders?	Yes
2	Whether logical and physical diagrams of the network and attached local and wide area networks, including the systems' vendor and model description, physical location, and applications and data residing and processing on the servers and workstations displayed?	Yes
3	Whether the documents related to the server and directory location of the significant application programs and data within the network; document the flow of transactions between systems and nodes in the network are documented.	Yes
4	Whether the trusted domains are under the same physical and administrative control and are logically located within the same sub-network.	Yes
5	Whether router filtering is used to prevent external network nodes from spoofing the IP address of a trusted domain.	Yes
6	Whether the Administrator/Super User and Guest accounts have passwords assigned to them.	Yes
7	Whether the account properties settings active in each user's individual profiles are reviewed?	Yes
8	Whether the security permissions for all system directories and significant application programs and directories are consistent with security policy.	Yes
9	Whether access permissions assigned to groups and individual accounts, Full Control (all permissions) and Change (Read, Write, Execute, and Delete) permissions are restricted to authorize users.	Yes
10	Whether audit log is reviewed for suspicious events and follow up on these events with the security administrator.	Yes
11	Whether all accounts had passwords and determine the strength of the passwords.	Yes
12	Whether simple network management protocol (SNMP) used to configure the network?	Yes

16	Determine the version of SNMP employed by the Company. (Version one stores passwords in clear-text format. Version two adds encryption of passwords.)	Yes
20	Whether users were properly authenticated when remotely accessing the routers.	Yes

AUDIT OF FIREWALL CONTROL OF THE DATA CENTER

The Firewall Controls are for controlling traffic between the corporate network and the Internet and the access to the network resources. Firewalls are set up to allow only specific Internet services and may provide additional services such as logging, authentication, encryption, and packet filtering.

CONTROL OBJECTIVES & PROCEDURE ADOPTED FOR AUDITING OF FIREWALL CONTROLS AT THE DATA CENTER

S. No	Audit Procedures	Yes/No
1	Is there is a Firewall Policy, and whether is it commensurate with the Organization requirements? Is it updated frequently?	Yes
2	Whether following information related to Firewall is available: Background information about the firewall e.g., segment diagrams, software, hardware, routers, version levels, host names, IP addresses, connections, any specific policies for an overview of the firewall security	Yes
3	Whether the firewall components, both logical and physical, agree with the firewall strategy.	Yes
4	Whether the firewall components are the latest possible version and security patches are current.	Yes
5	Whether there are no compilers/interpreters on the firewall.	Yes
6	Review the connections table for time out limits and number of connections	Yes
7	Whether the use of the firewall's automatic notification/alerting features and archiving the detail intruder information to a database for future analysis.	Yes
8	Review the audit logs for suspicious events and follow up on these events with the security administrator.	Yes

DOCUMENTS REVIEWED:

No.List of documents

1 Background of the ABC Bank and the Data Center

2 ABC Bank's Organizational chart

3 HR Personnel policy (NA)

4 Regulations and laws that affect the organization (for example – COBIT-19)

5 Security Policy

6 Networking Policy

7 Systems manual, User manual and Operations manual

8 List of applications and their details

9 Network and application architecture, including client- server architecture

10 Organizational structure of the IT department with job descriptions

11 IT department's responsibilities with reference to the specific application

12 Project management reports

13 Different Service Level Agreements – SLAs

14 Asset register for details of hardware

15 Details of software

16 Database details – Schema, Data Flow Diagram, Data Dictionary, Table listings

17 Details of interfaces with other systems

18 Performance analysis reports

19 List of users with permissions

20 Test data and test results

21 Security set up for the system

22 Internal audit reports

23 Previous audit reports

24 User feedback about the system

25 Peer review report

PROCESSES REVIEWED

Processes describe organized set of practices and activities to achieve certain objectives and produce a set of outputs in support of achieving overall IT-related goals.

During our audit for better understanding our team has reviewed and done walkthrough the data center process model for the following components:

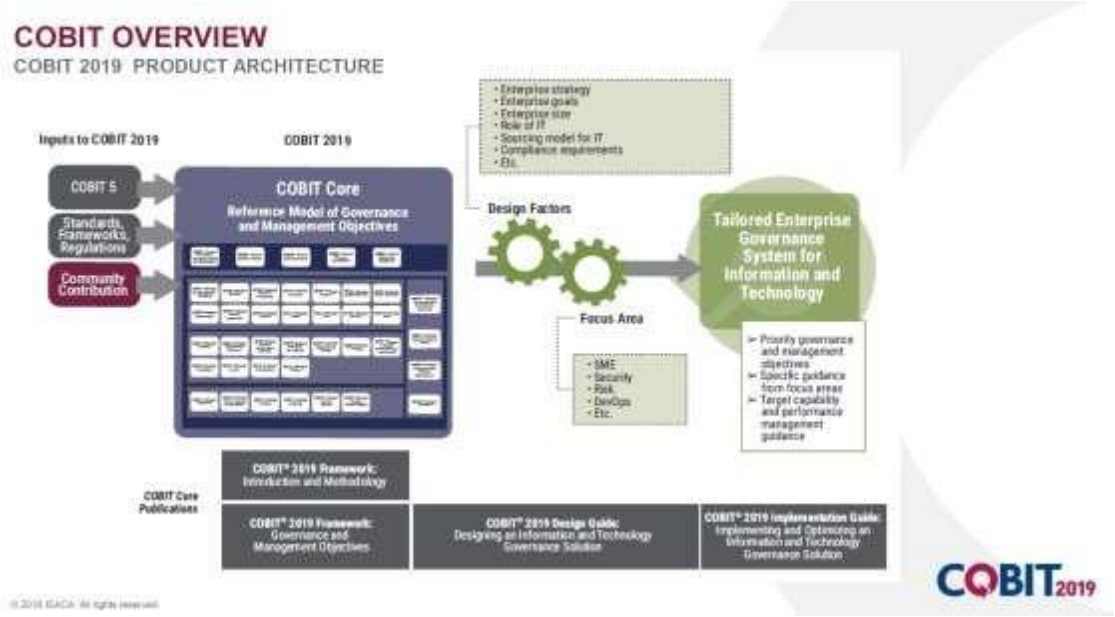
1. Application security
2. Cryptography
3. Monitoring

4. Incident management
5. Online banking security
6. Malware management
7. Data protection
8. Vendor (third-party) management
9. Business continuity planning
10. Privacy
11. Identity and access management
12. Risk management
13. Physical security
14. Awareness
15. Governance
16. Policy and Procedures
17. Asset life cycle management
18. Accountability and ownership
19. System configuration
20. Network security

We found that each of the components contributes to building the control standards and control procedures that satisfy high-level policy requirements.

We have followed bottom-up approach that serves to mitigate the top-level security concerns for bank's data center processes by providing adequate security for the assets used by these processes.

COBIT – 19

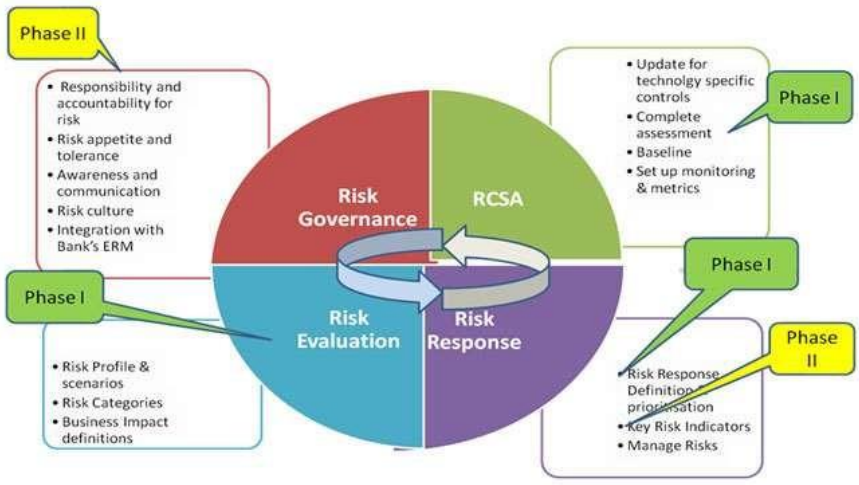


COBIT is a framework for the governance and management of enterprise information and technology, aimed at the whole enterprise. **COBIT** describes enablers, which are factors that, individually and collectively, influence governance and management of organization:

1. **Principles, policies, and frameworks** are the vehicles to translate a desired behavior into practical guidance for day-to-day management.
2. **Processes** describe an organized set of practices and activities to achieve certain objectives and produce a set of outputs in support of achieving overall IT-related goals.
3. **Organizational structures** are the key decision-making entities in an enterprise.
4. **Culture, ethics and behavior** of individuals and the enterprise are often underestimated as a success factor in governance and management activities.
5. **Information** is pervasive throughout any organization and includes all information produced and used by the enterprise. Information is required for keeping the organization running and well governed, but at the operational level, information is often the key product of the enterprise.
6. **Services, infrastructure, and applications** include the infrastructure, technology and applications that provide the enterprise with IT processing and services.
7. **People, skills, and competencies** are linked to people and are required for successful completion of all activities and for making correct decisions and taking corrective actions.

ABC bank was in the process of implementing a model in which COBIT can be used to meet the followings:

1. IT performance,
2. Audit and compliance requirements within the bank.
3. Creating a Risk Management Model



We were explained by the Bank the importance of a holistic approach, using COBIT enablers toward building a sustainable IT governance and risk management model for the bank.

The implementation was not complete.

ONLINE RESOURCES & REFERENCES:

1. COBIT – 19 Toolkit
   https://www.isaca.org/resources/cobit
2. COBIT® 2019 Framework: Introduction and Methodology
   COBIT® 2019 Framework: Governance and Management Objectives https://www.isaca.org/bookstore/bookstore-cobit_19-digital/wcb19fim
3. COBIT® 2019 Design Guide: Designing an Information and Technology

   https://www.isaca.org/bookstore/bookstore-cobit_19-digital/wcb19dgd
4. COBIT® 2019 Implementation Guide: Implementing and Optimizing an Information and Technology Governance Solution

   https://www.isaca.org/bookstore/bookstore-cobit_19-digital/wcb19igio

5. Information System Audit- ICAI Publication

DELIVERABLES

We have conducted an information systems audit of Data Center operations. Our audit focused on the management and protection of the central data center against physical, logical threats.

Our Audit Report contains five categories of recommendations addressing:

1. Implementing an overall process to ensure threats to the data center are addressed.
2. Implementing safeguards over physical security to deter unauthorized access.
3. Strengthening safeguards to mitigate threats.
4. Coordinating disaster recovery efforts.
5. Defining responsibilities for data center security and coordination.

We wish to express our appreciation to the Data Center department for their cooperation and assistance.

AUDIT FINDINGS

Audit Overview:

We have conducted the audit for determining whether the Bank has identified logical, physical threats to the data center, assessed the risk or impact presented by the threats, determined the feasibility of implementing controls to address the risks, implemented appropriate controls, and re-assess risks periodically.

Our Audit work included interviews with bank personnel, walkthroughs and inspections of the facilities, observations, and review of documentation and equipment configurations. We reviewed safeguards used to prevent unauthorized access to server operating systems and reviewed procedures to update and patch server operating systems. We reviewed physical controls, doorways and access systems, monitoring functions, and the physical layout of the data center.

FINDINGS - HIGHLIGHTS:

Data Center has controls in place for fire and heat, power surges and outages, and operating systems access and updates. In the areas of physical security controls are fragmented or nonexistent and can be improved.

Overall, there is not a process in place to ensure the continuity of data center operations or for management to make an informed decision about the appropriateness, cost effectiveness, and necessity of implementing data center controls. Data Center Infrastructure Cannot Easily Adapt to Changes in Operations.

Our audit reviewed the areas of:

1. Planning and Management,
2. Physical Security,
3. Environmental Security, and Recovery and Incident Response.
4. Details regarding controls in these areas.

The details regarding controls in these areas and conclusions are as follows:

1. INADEQUATE PHYSICAL FACILITIES

Physical and Network security was inadequate at the Bank's critical Data Center.

2. INADEQUATE/LACK OF DISASTER RECOVERY PLAN

The 20 Core Banking Solution branches are being run without any Disaster Recovery Plan thereby exposing the system to the risk of disruption of its operations in the event of any disaster. Bank has controls in place for fire and heat, power surges and outages, and operating systems access and updates. In the areas of physical security, the controls are fragmented or nonexistent and can be improved.

Bank performs damage control and remediation as problems arise but does not eliminate or reduce all known threats proactively.

3. IMPROPER MAINTENANCE OF ASSETS REGISTER

The Asset Register is not maintained by the Bank and Data Center makes it difficult to ascertain the location of the assets.

4. INADEQUATE IS SECURITY POLICY IMPLEMENTATION.

We have observed during audit that Bank had not formulated any Security Policy until 2015. In February 2015, an Information System Security Policy was formulated which appeared to us to be a promotional document of Network Solutions rather than an internal document of the Bank.
The policy documents were kept on Bank's intranet site which is restricted to System Administrators only and no other means of its dissemination to the operational level were adopted. This inadequate dissemination of the policy at branch level resulted in most of the staff being ignorant of this policy.

5. INADEQUATE SECURITY AT DATA CENTER

There were no Physical Access Controls for safeguarding critical areas like Server room, Communication room, UPS room. The access control system installed was not functioning and no alternate arrangements had been made. Even the doors did not have mechanical bolts/locks. Besides, access to a spare equipment room, which was also accessed by vendors, was through the Server room. Proper locking system at the main entry door (glass) was neither provided nor a Physical Security Officer appointed. Security Cameras were also inadequate.
There was no Annual Maintenance contract for critical systems like access lock system, CCTV, fire alarm, firefighting system. The UPS installed at Data Center had never been tested for fault tolerance.

6. INADEQUATE LOGICAL ACCESS CONTROLS

During our audit, we found that default passwords were running and had not been changed by System Administrator. No undertaking from users for maintaining the confidentiality of password was not obtained.

7. INADEQUATE NETWORK SECURITY CONTROLS

During the Audit, we observed the following security deficiencies in the network:

a. There was not any Intrusion Prevention System (IPS) or Enterprise Security Solutions in place for services like e-Banking etc. to its customers.

b. Network penetration testing was not conducted by an independent agency. Instead, the Bank had got "Internet Banking Security Assessment" done from the vendor for all their networking projects.

c. Data Center had not adopted Network Time Protocol (NTP) for synchronization of all routers in case of power disruption.

8. INADEQUATE DOCUMENTATION AND CHANGE MANAGEMENT CONTROL.

Effective preparation, distribution, control, and maintenance of documentation is helpful in reuse, conversion, correction, and enhancement of the IT system.

During Audit, we found slackness in maintaining the proper documentation of various activities such as backups, password changing (activation and deactivation), declaration from staff regarding maintaining secrecy of passwords, software problem register, AMC register, IT assets inventory register etc. Poor implementation of Backup Controls

We observed that, a back-up policy had been adopted by the Bank and the backups were being taken at regular intervals (daily, weekly, fortnightly), but the procedures associated with documentation, safe custody and testing were not being uniformly implemented as proper backup registers depicting the daily backup processes and storage and testing details had not been maintained.

9. **Inadequate Application specific Controls:**

    a. Inadequate control over inoperative Accounts

    b. Incomplete/incorrect data migration

10. **Inadequate robust and transparent acquisition policy** resulting in non-competitive purchases and ad hoc procurements

S.No.	Control Objectives	Audit Procedure	Risk Ranking	Observation	Impact	Recommendations
1	**Maintenance of Asset Register**	Observation, Conformation	High	Asset register not updated and reviewed for last 2 yrs. Asset register does not have the detials of ownership and location	Assets Unidentified (C,A)	Asset Register should be reviewed and updated immediately with ownership and location detials
2	**Logical Access Control**	Observation, Conformation Questionare	High	All Menus are accessible to all the users	Some Critical operations may be compromised (C,I)	Menu access should be duly authorised and given to restricted authorities only
3	**Physical Access Control**	Observation, Conformation Questionare	Medium	No Biometrics Access Control at the entry gates of data centre	Unauthorized Access increases the risk of losing critical data (C,I,A)	Strict Biometric Authorization should be implemented
4	**Logical Access Control**	Observation, Conformation Questionare	Medium	Incident Management reports information of voilation cases	Voilation of Access Control (C,I)	Analyze reasons for such incidence and initiate corrective actions
5	**Logical Access Control**	Observation, Conformation Questionare	High	Testing and Devlopment team sharing data in same server	Test results might have been compromised (C,I)	Test server and Development server to be separated both physically and logically
6	**Duties Segregation**	Observation, Conformation Questionare	High	Testing and Production team has access to server	Data in the prodcution server can be changed during testing (C,I)	Restrict the access of Procudtion Server Room
7	**Version Control Management**	Observation, Conformation	High	Not maintained	No Librarian (I)	Librarian to be appointed for maintenance of Version Control
8	**Change Management**	Observation, Conformation	High	Gap in implementing & testing as the change management process is manual	Time Lag will increase Control Risk (C,I)	Install application driven change management process

RISK ASSESSMENT / RECOMMENDATIONS

9	**User Access Controls**	Observation, Conformation	Medium	User access review is a manual process	Without having regular user access control process review it is very likely that unauthorised user ID remians in the system. (C,I,A)	User Access Control should be reviewed regularly and all the unauthorised user IDs should be deactivated asap

C	Confidentiality
I	Integrity
A	Availability

RISK RANKING

Assigning Likelihood Level		
Likelihood Level	Value	Likelihood Definition
Very High	5	The threat-source is highly motivated and sufficiently capable, and controls to prevent the vulnerability from being exercised are absent/ ineffective. Occurrence is frequent.
High	4	The threat-source is motivated and capable, and controls that impede successful exercise of vulnerability or detect the impact are ineffective. Occurrence is regular.
Medium	3	The threat-source is motivated, but not sufficiently capable or controls that may detect the exercise of the vulnerability are present. Occurrence is periodic.
Low	2	The threat-source is motivated, but not sufficiently capable or controls that may impede successful exercise of the vulnerability are present. Occurrence is low.
Negligible	1	The threat-source lacks motivation or capability, or controls are in place to prevent, or at least significantly impede, the vulnerability from being exercised. Not occurred till now and may not occur in future.

S.No	Control Objectives	Audit Procedures	Risk (Ranking)			Risk (Impact)		
			High	Medium	Low	Confidentiality	Integrity	Availability
1	Inadequate IS Security Policy implementation	Inspection, Observations, Inquiry, Confirmation.						
2	Inadequate security at Data Centre	Inspection, Observations, Inquiry, Confirmation.						
3	Inadequate Network Security	Inspection, Observations, Inquiry, Confirmation						
4	Logical Access Controls	Inspection, Observations, Inquiry, Confirmation						
5	Inadequate Documentation and Change Management Control	Inspection, Observations, Inquiry, Confirmation						
6	Inadequate IT Assets Inventory Management	Inspection, Observations, Inquiry, Confirmation, Recalculation, reperformance Analytical procedures						

SUMMARY/CONCLUSION

The objective of our audit of data center was to evaluate against applicable standards to ensure the security and availability of technology assets and to provide information technology services. We are pleased to conclude the results of our audit.

The audit revealed that ABC Bank need to address several issues and improve their data center operations. The Data Center needs to implement new controls over the management of critical data center facilities.

The operations of Data Center can be improved by addressing weak environmental

controls, by improving ongoing software application reviews, and by implementing cost accounting practices. In addition, developing and implementing policies and procedures for technology infrastructure will help Data Center prevent system failures that could cause a loss of data? Our report lists several related recommendations to address these concerns. In addition, we identified security-related findings, which have been communicated separately to management of Bank and the Data Center.

Our Audit Report contains five categories of recommendations addressing:

1. Implementing an overall process to ensure threats to the data center are addressed.

2. Implementing safeguards over physical security to deter unauthorized access.

3. Strengthening safeguards to mitigate threats.

4. Coordinating disaster recovery efforts.

5. Defining responsibilities for data center security and coordination.

RECOMMENDATIONS:

1. Data Center must "implement appropriate cost-effective safeguards to reduce, eliminate, or recover from identified threats to data." Data Center has the custodial responsibility to protect the data center with safeguards proportional to the importance of the equipment residing in the data center and the extent of potential loss. Data Center must identify what equipment it is protecting, threats to the equipment, potential safeguards, and associated costs to implement the safeguards.

2. Data Center must plan for their assets and operations and sets the tone for the level of protection by understanding what equipment and systems reside in the data center, knowing where the responsibility for protection lies, knowing what controls are in place and what are lacking, and mitigating the identified threats to the extent possible.

3. Access policy should be periodically reviewed to ensure the approved security level is maintained

4. Maintain and update the inventory of equipment, systems, and data residing in the data center.
5. Coordinate with all agencies that have hosted systems in the data center to rank the systems' criticality and establish a priority.
6. Evaluate existing threats to the data center including the potential impact or harm.
7. Conduct a cost analysis associated with implementing or improving controls.
8. Define the responsibility for, and coordinate with agencies to utilize the existing software package to develop disaster recovery plans.
9. Implement safeguards such as locked doors in the Data Center building.
10. Implement procedures and assign responsibilities for ensuring background checks are complete.
11. Follow Security policy and maintain required authorization documentation on file for each individual who has access to the data center.
12. Conduct a periodic review of all key card access to the data center to confirm appropriateness.
13. Monitor and review card activity logs and data center visitor logs for inappropriate or unauthorized access.
14. Develop a system to ensure operator awareness of physical security breaches.
15. We recommend the Data Center to strengthen safeguards to mitigate the environmental risks.
16. We recommend the Data Center to clearly define and designate responsibility for coordination of all aspects of data center security.
17. We recommend the Data Center to maintain an updated disaster recovery plan.